# เอกสารประกอบการปฏิบัติการ
## รายวิชา CP423324 Database and Web Security
## Lab 11: Authorization and CSRF Protection
## (การควบคุมสิทธิ์และการป้องกัน CSRF)

**วัตถุประสงค์**

1. เพื่อให้นักศึกษาสามารถตรวจสอบสิทธิ์ของผู้ใช้ก่อนดู แก้ไข และลบข้อมูลที่ฝั่ง Server โดยใช้ Role และ Ownership Check ได้
2. เพื่อให้นักศึกษาสามารถใช้คำขอแบบ POST ร่วมกับ CSRF Token สำหรับการเพิ่ม แก้ไข ลบข้อมูล และการปรับปรุงข้อมูล Profile ได้
3. เพื่อให้นักศึกษาสามารถทดสอบการเข้าถึงข้อมูลโดยไม่มีสิทธิ์ และทดสอบคำขอปลอมที่ไม่มี CSRF Token ได้

**คำชี้แจง**

1. ให้นักศึกษา Capture ผลลัพธ์ตามที่งานของแต่ละข้อกำหนดลงใน Word และบันทึกไฟล์เป็น PDF โดยให้ตั้งชื่อว่า Lab11_รหัสนักศึกษา(มีขีด).pdf
2. เมื่อทำเสร็จเรียบร้อยแล้วให้แจ้งผู้ช่วยสอน (TA) เพื่อขอรับการตรวจและตอบคำถาม (กรุณาตรวจกับพี่ TA โดยคะแนนจะมาจากการตรวจในห้องเรียน)
3. เมื่อตรวจกับ TA เรียบร้อยแล้วให้นักศึกษาส่งใน Classroom เพื่อเป็นการสำรองข้อมูล
4. ไม่อนุญาตให้ส่งงานย้อนหลังได้ ยกเว้นกรณีลาป่วย หรืออุบัติเหตุ (ต้องมีใบรับรองแพทย์)

★★★★★★★★★★

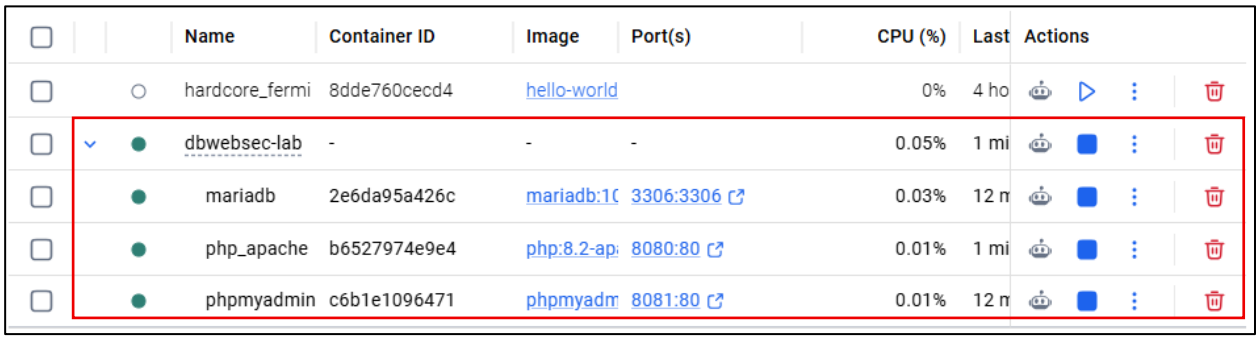
## โจทย์ที่กำหนด

งานปฏิบัติการนี้ให้นักศึกษาพัฒนาเว็บแอปพลิเคชันต่อจากระบบข้อมูลหนังสือ จาก Lab10 ระบบ Book Comment / Review โดยเพิ่มส่วนของ User Profile เพื่อใช้ทดสอบ Authorization และ CSRF Protection โดยกำหนดบทบาทผู้ใช้เป็น user และ admin และป้องกัน State-Changing Action ได้แก่ Add, Edit, Delete และ Update Profile ด้วย CSRF Token โดยมีผู้ใช้จำลอง 3 บัญชี: student01 (user), student02 (user) และ admin01 (admin)

| Role | การดูข้อมูล Comment | การแก้ไขและลบ Comment | การดูและแก้ไข Profile |
|---|---|---|---|
| user | เฉพาะตนเอง | เฉพาะตนเอง | แก้ Profile ของตนเอง |
| admin | ทุกคนผ่านหน้า Admin | ทุกคน | แก้ Profile ของตนเอง |

มีขั้นตอนการพัฒนาระบบ ดังนี้

1. เปิด docker ที่เคยสร้างไว้ ให้ Start container name: dbwebsec-lab, mariadb, php_apache และ phpmyadmin




2. การใช้ฐานข้อมูลชื่อ db_lab08 และตาราง books, book_comments เดิมจาก Lab10 จากนั้นเพิ่มตาราง user_profiles สำหรับทดสอบการแก้ไข Profile และการป้องกัน CSRF ซึ่งมีรายละเอียดของตาราง user_profiles ดังนี้

| Field | Data Type | ข้อกำหนด | ความหมาย |
|---|---|---|---|
| user_id | INT | PRIMARY KEY, AUTO_INCREMENT | รหัสผู้ใช้งาน |
| username | VARCHAR(50) | NOT NULL, UNIQUE | ชื่อบัญชีสำหรับจำลองผู้ใช้ |
| display_name | VARCHAR(50) | NOT NULL | ชื่อที่แสดง |
| email | VARCHAR(50) | NOT NULL | อีเมล |

ตัวอย่างคำสั่ง SQL

สร้างตาราง user_profiles

```
CREATE TABLE IF NOT EXISTS user_profiles (
    user_id INT AUTO_INCREMENT PRIMARY KEY,
    username VARCHAR(50) NOT NULL UNIQUE,
    display_name VARCHAR(100) NOT NULL,
    email VARCHAR(150) NOT NULL
) CHARACTER SET utf8mb4
  COLLATE utf8mb4_unicode_ci;
```

ผลลัพธ์จากการสร้างตาราง user_profiles ดังนี้

| # | Name | Type | Collation | Attributes | Null | Default | Comments | Extra |
|---|---|---|---|---|---|---|---|---|
| 1 | **user_id** | int(11) | | | No | *None* | | AUTO_INCREMENT |
| 2 | **username** | varchar(50) | utf8mb4_unicode_ci | | No | *None* | | |
| 3 | **display_name** | varchar(100) | utf8mb4_unicode_ci | | No | *None* | | |
| 4 | **email** | varchar(150) | utf8mb4_unicode_ci | | No | *None* | | |

จากนั้นเพิ่มข้อมูลในตาราง book_ profiles ด้วยคำสั่ง SQL ดังนี้

```
INSERT INTO user_profiles (username, display_name, email) VALUES
('student01', 'Student 01', 'student01@example.com'),
('student02', 'Student 02', 'student02@example.com'),
('admin01',   'Administrator', 'admin01@example.com')
ON DUPLICATE KEY UPDATE
    display_name = VALUES(display_name),
    email = VALUES(email);
```

ผลลัพธ์จากการการเพิ่มข้อมูล ดังนี้

| user_id | username | display_name | email |
|---|---|---|---|
| 1 | student01 | Student 01 | student01@example.com |
| 2 | student02 | Student 02 | student02@example.com |
| 3 | admin01 | Administrator | admin01@example.com |

ใน Lab นี้จำลองผู้ใช้ เพื่อใช้สาธิตการตรวจสอบความเป็นเจ้าของข้อมูล (Ownership) เท่านั้น ไม่ใช่ระบบ Authentication

จากนั้นเพิ่มสิทธิ์ให้ webapp_user

```
GRANT SELECT
ON db_lab08.books
TO 'webapp_user'@'%';

GRANT SELECT, INSERT, UPDATE, DELETE
ON db_lab08.book_comments
TO 'webapp_user'@'%';

GRANT SELECT, UPDATE
ON db_lab08.user_profiles
TO 'webapp_user'@'%';
```

3. การสร้างเว็บแอปพลิเคชัน

ให้นักศึกษาสร้างโฟลเดอร์ Lab11 ไว้ภายใน C:\dbwebsec-lab\www สำหรับไฟล์ที่ต้องสร้างมีไฟล์ทั้งหมด 12 ไฟล์ มีรายละเอียด ดังนี้

1) Lab11_config.php เชื่อมต่อฐานข้อมูล, Session, Role, h(), CSRF Token และ helper Authorization (ไฟล์ปรับจากโค้ด Lab10)
2) Lab11_select_user.php จำลองสถานะผู้ใช้ใน Session เพื่อใช้ทดสอบ Authorization โดยไม่ใช่ระบบ Authentication จริง (ไฟล์สร้างใหม่)
3) Lab11_comments_secure.php หน้า Comment หลักของผู้ใช้ พร้อม Add Form และ Edit/Delete UI (ไฟล์ปรับจากโค้ด Lab10)
4) Lab11_add_comment.php รับ POST เพื่อเพิ่ม Comment และตรวจ CSRF Token (ไฟล์ปรับจากโค้ด Lab10)

5) Lab11_edit_form.php โหลด Comment, ตรวจ Authorization และแสดง Edit Form พร้อม CSRF Token (ไฟล์ปรับจากโค้ด Lab10)
6) Lab11_edit_comment.php ตรวจ POST + CSRF + Input + Authorization ก่อน UPDATE (ไฟล์ปรับจากโค้ด Lab10)
7) Lab11_delete_comment.php ตรวจ POST + CSRF + Authorization ก่อน DELETE (ไฟล์ปรับจากโค้ด Lab10)
8) Lab11_admin_comments.php หน้าเฉพาะ admin สำหรับดู/แก้/ลบ Comment ของทุกคน (ไฟล์สร้างใหม่)
9) Lab11_profile.php หน้า Profile ของผู้ใช้และ Secure Update Form (ไฟล์สร้างใหม่)
10) Lab11_update_profile_before_csrf.php Endpoint สำหรับทดสอบกรณีที่ยังไม่ตรวจ CSRF Token (ไฟล์สร้างใหม่)
11) Lab11_update_profile.php Secure Endpoint ที่ตรวจ CSRF Token ก่อน UPDATE Profile (นักศึกษาสร้างเอง)
12) Lab11_fake_profile_update.html จำลอง Forged POST ก่อนและหลัง CSRF Protection (เตรียมไว้ให้)

รายละเอียดของแต่ละไฟล์ ดังนี้

### 3.1 การสร้างไฟล์ Lab11_config.php โดยมีคำสั่ง ดังนี้

```php
<?php
declare(strict_types=1);

session_start();
date_default_timezone_set('Asia/Bangkok');

const DB_HOST = 'db';
const DB_PORT = 3306;
const DB_NAME = 'db_lab08';
const DB_USER = 'webapp_user';
const DB_PASS = 'WebApp1234';

mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);

try {
    $conn = new mysqli(DB_HOST, DB_USER, DB_PASS, DB_NAME, DB_PORT);
    $conn->set_charset('utf8mb4');
    $conn->query("SET time_zone = '+07:00'");
} catch (mysqli_sql_exception $e) {
    http_response_code(500);
    error_log($e->getMessage());
    exit('Database connection failed.');
}

function h(?string $value): string
{
    return htmlspecialchars($value ?? '', ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8');
}

/* ส่วนที่เพิ่มใน Lab11
 * จำลอง Authentication + Role
 * ถ้ายังไม่ได้เลือกผู้ใช้จาก Lab11_select_user.php
 * ให้ student01 / user เป็นค่าเริ่มต้น
 */
$_SESSION['username'] ??= 'student01';
$_SESSION['role'] ??= 'user';

$currentUser = $_SESSION['username'];
$currentRole = $_SESSION['role'];

if (empty($_SESSION['csrf_token'])) {
    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
}

/* ตรวจ Role */
function is_admin(string $role): bool
{
    return $role === 'admin';
}

```

```php
/* ตรวจrole และ Ownership Authorization */
function can_modify_comment(
    string $createdBy,
    string $currentUser,
    string $currentRole
): bool {
    return is_admin($currentRole) || $createdBy === $currentUser;
}

/* ตรวจ CSRF Token */
function verify_csrf_token(): void
{
    $token = $_POST['csrf_token'] ?? '';

    if (
        !is_string($token) ||
        !isset($_SESSION['csrf_token']) ||
        !hash_equals($_SESSION['csrf_token'], $token)
    ) {
        http_response_code(403);
        exit('Invalid request.');
    }
}
```

3.2 Lab11_select_user.php จำลอง Authentication เพื่อสลับ student01 / student02 / admin01 (ไฟล์สร้างใหม่)

```php
<?php
require_once 'Lab11_config.php';
/* จำลอง Authentication สำหรับทดสอบ Authorization
 * ไม่ใช่ระบบ Login จริง ใช้สำหรับสลับผู้ใช้และ Role ใน Lab เท่านั้น
 * student01 -> user
 * student02 -> user
 * admin01   -> admin
 */
$accounts = [
    'student01' => 'user',
    'student02' => 'user',
    'admin01'   => 'admin',
];
```

```php
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $username = $_POST['username'] ?? '';

    if (!isset($accounts[$username])) {
        http_response_code(400);
        exit('Invalid user.');
    }

    $_SESSION['username'] = $username;
    $_SESSION['role'] = $accounts[$username];

    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
    header('Location: Lab11_comments_secure.php');
    exit;
}
?>
```

```html
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Lab11 - Select User</title>
    <style>
        body {
            font-family: Arial, sans-serif;
            max-width: 900px;
            margin: 32px auto;
            padding: 0 16px;
            line-height: 1.5
        }
        .actions {
            display: flex;
            gap: 8px;
            margin-top: 10px;
            align-items: center
        }
        .actions form {
            margin: 0
        }
```

```
        button,
        .button-link {
            display: inline-flex;
            align-items: center;
            justify-content: center;
            min-width: 80px;
            height: 36px;
            padding: 0 12px;
            border: 1px solid #888;
            border-radius: 4px;
            background: #f5f5f5;
            color: #111;
            text-decoration: none;
            cursor: pointer;
            box-sizing: border-box;
            font: inherit
        }
        .nav-actions {
            display: flex;
            gap: 8px;
            flex-wrap: wrap;
            margin: 12px 0 20px
        }
        select {
            width: auto;
            padding: 6px 10px;
            font-size: 16px;
        }
    </style>
</head>

<body>
    <h1>Select User for Lab11</h1>
    <p>This page simulates Authentication for testing Authorization.</p>
    <p>
        Current user: <strong><?= h($currentUser) ?></strong>
        | Role: <strong><?= h($currentRole) ?></strong>
    </p>
    <form method="post">
        <label for="username">Login as:</label>
        <select name="username" id="username" required>
            <option value="student01">student01 (user)</option>
            <option value="student02">student02 (user)</option>
            <option value="admin01">admin01 (admin)</option>
        </select>
        <div class="actions">
            <button type="submit">Switch User</button>
        </div>
    </form>
    <p><a class="button-link" href="Lab11_comments_secure.php">Back to Comments</a></p>
</body>
</html>
```

3.3 Lab11_comments_secure.php หน้า Comment หลักของผู้ใช้ พร้อม Add Form และ Edit/Delete UI (ไฟล์ปรับจากโค้ด Lab10)

```php
<?php
require_once 'Lab11_config.php';
$message = $_GET['message'] ?? '';
$books = $conn->query('SELECT id, title FROM books ORDER BY title');
/*
 * Authorization สำหรับการดู
 * user เห็นเฉพาะ Comment ของตนเอง
 * admin ถ้าต้องการดูทั้งหมดให้ใช้ Lab11_admin_comments.php
 */
$stmt = $conn->prepare(
    'SELECT c.id, c.book_id, b.title, c.created_by, c.comment, c.created_at
     FROM book_comments c
     JOIN books b ON b.id = c.book_id
     WHERE c.created_by = ?
     ORDER BY c.id DESC'
);
$stmt->bind_param('s', $currentUser);
$stmt->execute();
$result = $stmt->get_result();
?>


<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Lab11 - My Book Comments</title>
    <style>
        body {
            font-family: Arial, sans-serif;
            max-width: 900px;
            margin: 32px auto;
            padding: 0 16px;
            line-height: 1.5
        }
        .actions {
            display: flex;
            gap: 8px;
            margin-top: 10px;
            align-items: center
        }
        .actions form {
            margin: 0
        }
```

```
        button,
        .button-link {
            display: inline-flex;
            align-items: center;
            justify-content: center;
            min-width: 80px;
            height: 36px;
            padding: 0 12px;
            border: 1px solid #888;
            border-radius: 4px;
            background: #f5f5f5;
            color: #111;
            text-decoration: none;
            cursor: pointer;
            box-sizing: border-box;
            font: inherit
        }
        .nav-actions {
            display: flex;
            gap: 8px;
            flex-wrap: wrap;
            margin: 12px 0 20px
        }
        select {
            width: auto;
            padding: 6px 10px;
            font-size: 16px;
        }
    </style>
</head>

<body>
    <h1>My Book Comments</h1>
    <p>
        Current user: <strong><?= h($currentUser) ?></strong>
        | Role: <strong><?= h($currentRole) ?></strong>
    </p>
    <?php if (is_admin($currentRole)): ?>
        <!-- เมนู Admin -->
        <p><a class="button-link" href="Lab11_admin_comments.php">View All Comments</a></p>
    <?php endif; ?>
    <div class="nav-actions"><a class="button-link" href="Lab11_profile.php">My Profile</a>
        <!-- สลับผู้ใช้/Role เพื่อทดสอบ Authorization -->
        <a class="button-link" href="Lab11_select_user.php">Switch User / Role</a>
    </div>
    <?php if ($message !== ''): ?>
        <p><?= h($message) ?></p>
    <?php endif; ?>
    <h2>Add Comment</h2>
    <form method="post" action="Lab11_add_comment.php">
        <label for="book_id">Book:</label>
        <select name="book_id" id="book_id" required>
            <option value="">-- Select Book --</option>
            <?php while ($book = $books->fetch_assoc()): ?>
                <option value="<?= (int)$book['id'] ?>"><?= h($book['title']) ?>
                </option>
            <?php endwhile; ?>
        </select><br>
```

```
        <label for="comment">Comment:</label> <br>
        <textarea name="comment" id="comment" maxlength="500" required></textarea>
        <!-- การ Add ต้องส่ง CSRF Token -->
        <input type="hidden" name="csrf_token"
            value="<?= h($_SESSION['csrf_token']) ?>"> <br>
        <button type="submit">Add Comment</button>
    </form>
    <hr>

    <h2>My Comments</h2>
    <?php while ($row = $result->fetch_assoc()): ?>
        <article>
            <h3><?= h($row['title']) ?></h3>
            <p>By: <?= h($row['created_by']) ?> | <?= h($row['created_at']) ?></p>
            <p><?= h($row['comment']) ?></p>
            <?php if (can_modify_comment($row['created_by'], $currentUser, $currentRole)): ?>
                <a class="button-link"
                href="Lab11_edit_form.php?id=<?= (int)$row['id'] ?>">Edit</a>
                <form method="post" action="Lab11_delete_comment.php"
                    style="display:inline"
                    onsubmit="return confirm('Delete this comment?');">
                    <input type="hidden" name="comment_id"
                        value="<?= (int)$row['id'] ?>">
                    <input type="hidden" name="csrf_token"
                        value="<?= h($_SESSION['csrf_token']) ?>">
                    <button type="submit">Delete</button>
                </form>
            <?php endif; ?>
        </article>
        <hr>
    <?php endwhile; ?>
</body>
</html>
```

3.4 Lab11_add_comment.php รับ POST เพื่อเพิ่ม Comment และตรวจ CSRF Token (ไฟล์ปรับจากโค้ด Lab10)

```
<?php
require_once 'Lab11_config.php';
if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    http_response_code(405);
    exit('Method not allowed.');
}
/* ตรวจ CSRF Token */
verify_csrf_token();

$bookId = filter_input(INPUT_POST, 'book_id', FILTER_VALIDATE_INT);
$comment = trim($_POST['comment'] ?? '');

if (!$bookId || $comment === '' || mb_strlen($comment, 'UTF-8') > 500) {
    http_response_code(400);
    exit('Invalid request.');
}

$stmt = $conn->prepare('SELECT id FROM books WHERE id = ?');
$stmt->bind_param('i', $bookId);
$stmt->execute();

```

```php
if (!$stmt->get_result()->fetch_assoc()) {
    http_response_code(404);
    exit('Book not found.');
}

$stmt = $conn->prepare(
    'INSERT INTO book_comments (book_id, created_by, comment)
     VALUES (?, ?, ?)'
);
$stmt->bind_param('iss', $bookId, $currentUser, $comment);
$stmt->execute();
header('Location: Lab11_comments_secure.php?message=' . urlencode('Comment saved.'));
exit;
```

3.5 Lab11_edit_form.php โหลด Comment, ตรวจ Authorization และแสดง Edit Form พร้อม CSRF Token (ไฟล์ปรับจากโค้ด Lab10)

```php
<?php
require_once 'Lab11_config.php';
$id = filter_input(INPUT_GET, 'id', FILTER_VALIDATE_INT);
if (!$id) {
    http_response_code(400);
    exit('Invalid request.');
}
$stmt = $conn->prepare(
    'SELECT c.id, c.created_by, c.comment, b.title
     FROM book_comments c
     JOIN books b ON b.id = c.book_id
     WHERE c.id = ?'
);
$stmt->bind_param('i', $id);
$stmt->execute();


$commentRow = $stmt->get_result()->fetch_assoc();
if (!$commentRow) {
    http_response_code(404);
    exit('Comment not found.');
}
/* ตรวจ Ownership
 * และ admin สามารถแก้ของทุกคนได้ / user สามารถแก้เฉพาะของตนเอง
 */
if (!can_modify_comment($commentRow['created_by'], $currentUser, $currentRole)) {
    http_response_code(403);
    exit('Access denied.');
}
?>
```

```
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Edit Comment</title>
    <style>
        body {
            font-family: Arial, sans-serif;
            max-width: 900px;
            margin: 32px auto;
            padding: 0 16px;
            line-height: 1.5
        }
        .actions {
            display: flex;
            gap: 8px;
            margin-top: 10px;
            align-items: center
        }
        .actions form {
            margin: 0
        }

        button,
        .button-link {
            display: inline-flex;
            align-items: center;
            justify-content: center;
            min-width: 80px;
            height: 36px;
            padding: 0 12px;
            border: 1px solid #888;
            border-radius: 4px;
            background: #f5f5f5;
            color: #111;
            text-decoration: none;
            cursor: pointer;
            box-sizing: border-box;
            font: inherit
        }
        .nav-actions {
            display: flex;
            gap: 8px;
            flex-wrap: wrap;
            margin: 12px 0 20px
        }
    </style>
</head>
```

```
<body>
    <h1>Edit Comment</h1>
    <p>Book: <strong><?= h($commentRow['title']) ?></strong></p>
    <p>Owner: <strong><?= h($commentRow['created_by']) ?></strong></p>
    <form method="post" action="Lab11_edit_comment.php">
        <input type="hidden" name="comment_id" value="<?= (int)$commentRow['id'] ?>">
        <label for="comment">Comment:</label> <br>
        <textarea name="comment" id="comment" maxlength="500" required><?= h($commentRow['comment']) ?>
        </textarea><br> <br>
        <!-- Form ต้องส่ง CSRF Token -->
        <input type="hidden" name="csrf_token"
            value="<?= h($_SESSION['csrf_token']) ?>">
        <button type="submit">Save Changes</button>
        <a class="button-link" href="Lab11_comments_secure.php">Cancel</a>
    </form>
</body>
</html>
```

3.6 Lab11_edit_comment.php ตรวจ POST + CSRF + Input + Authorization ก่อน UPDATE (ไฟล์ปรับจากโค้ด Lab10)

```
<?php
require_once 'Lab11_config.php';
if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    http_response_code(405);
    exit('Method not allowed.');
}
/* ตรวจ CSRF Token */
verify_csrf_token();
$id = filter_input(INPUT_POST, 'comment_id', FILTER_VALIDATE_INT);
$newComment = trim($_POST['comment'] ?? '');
if (!$id || $newComment === '' || mb_strlen($newComment, 'UTF-8') > 500) {
    http_response_code(400);
    exit('Invalid request.');
}
$stmt = $conn->prepare(
    'SELECT id, created_by
     FROM book_comments
     WHERE id = ?'
);
$stmt->bind_param('i', $id);
$stmt->execute();
$commentRow = $stmt->get_result()->fetch_assoc();
```

```php
if (!$commentRow) {
    http_response_code(404);
    exit('Comment not found.');
}
/* ตรวจ Role และ Ownership Authorization */
if (!can_modify_comment($commentRow['created_by'], $currentUser, $currentRole)) {
    http_response_code(403);
    exit('Access denied.');
}
$stmt = $conn->prepare(
    'UPDATE book_comments
     SET comment = ?
     WHERE id = ?'
);
$stmt->bind_param('si', $newComment, $id);
$stmt->execute();
header('Location: Lab11_comments_secure.php?message=' . urlencode('Comment updated.'));
exit;
```

3.7 Lab11_delete_comment.php ตรวจ POST + CSRF + Authorization ก่อน DELETE (ไฟล์ปรับจากโค้ด Lab10)

```php
<?php
require_once 'Lab11_config.php';
if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    http_response_code(405);
    exit('Method not allowed.');
}
/* ตรวจสอบ CSRF Token สำหรับ Delete โดยใช้ function เดียวกับ Add/Edit
 */
verify_csrf_token();
$id = filter_input(INPUT_POST, 'comment_id', FILTER_VALIDATE_INT);
if (!$id) {
    http_response_code(400);
    exit('Invalid request.');
}
$stmt = $conn->prepare(
    'SELECT id, created_by
     FROM book_comments
     WHERE id = ?'
);
$stmt->bind_param('i', $id);
$stmt->execute();
$commentRow = $stmt->get_result()->fetch_assoc();

```

```php
if (!$commentRow) {
    http_response_code(404);
    exit('Comment not found.');
}
/* ตรวจสอบ Role และ Ownership Authorization */
if (!can_modify_comment($commentRow['created_by'], $currentUser, $currentRole)) {
    http_response_code(403);
    exit('Access denied.');
}
$stmt = $conn->prepare(
    'DELETE FROM book_comments WHERE id = ?'
);
$stmt->bind_param('i', $id);
$stmt->execute();
header('Location: Lab11_comments_secure.php?message=' . urlencode('Comment deleted.'));
exit;
```

3.8 Lab11_admin_comments.php หน้าเฉพาะ admin สำหรับดู/แก้/ลบ Comment ของทุกคน (ไฟล์สร้างใหม่)

```php
<?php
require_once 'Lab11_config.php';
/* Authorization สำหรับหน้า Admin
 */
if (!is_admin($currentRole)) {
    http_response_code(403);
    exit('Access denied.');
}
$result = $conn->query(
    'SELECT c.id, c.book_id, b.title, c.created_by, c.comment, c.created_at
     FROM book_comments c
     JOIN books b ON b.id = c.book_id
     ORDER BY c.id DESC'
);
?>
```

```html
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>Admin - All Comments</title>
    <style>
        body {
            font-family: Arial, sans-serif;
            max-width: 900px;
            margin: 32px auto;
            padding: 0 16px;
            line-height: 1.5
        }
        .actions {
            display: flex;
            gap: 8px;
            margin-top: 10px;
            align-items: center
        }
        .actions form {
            margin: 0
        }
```

```
        button,
        .button-link {
            display: inline-flex;
            align-items: center;
            justify-content: center;
            min-width: 80px;
            height: 36px;
            padding: 0 12px;
            border: 1px solid #888;
            border-radius: 4px;
            background: #f5f5f5;
            color: #111;
            text-decoration: none;
            cursor: pointer;
            box-sizing: border-box;
            font: inherit
        }

        .nav-actions {
            display: flex;
            gap: 8px;
            flex-wrap: wrap;
            margin: 12px 0 20px
        }
    </style>
</head>

<body>
    <h1>Admin: All Book Comments</h1>
    <p>Current user: <?= h($currentUser) ?> | Role: <?= h($currentRole) ?></p>
    <p><a class="button-link" href="Lab11_comments_secure.php">Back to My Comments</a></p>
    <?php while ($row = $result->fetch_assoc()): ?>
        <article>
            <h3><?= h($row['title']) ?></h3>
            <p>By: <?= h($row['created_by']) ?> | <?= h($row['created_at']) ?></p>
            <p><?= h($row['comment']) ?></p>
            <div class="actions">
                <a class="button-link" href="Lab11_edit_form.php?id=<?= (int)$row['id'] ?>">Edit</a>
                <form method="post" action="Lab11_delete_comment.php"
                    onsubmit="return confirm('Delete this comment?');">
                    <input type="hidden" name="comment_id" value="<?= (int)$row['id'] ?>">
                    <input type="hidden" name="csrf_token"
                        value="<?= h($_SESSION['csrf_token']) ?>">
                    <button type="submit">Delete</button>
                </form>
            </div>
        </article>
        <hr>
    <?php endwhile; ?>
</body>
</html>
```

3.9 Lab11_profile.php หน้า Profile ของผู้ใช้และ Secure Update Form (ไฟล์สร้างใหม่)

```php
<?php
require_once 'Lab11_config.php';
/* Profile ใช้สาธิต CSRF แบบ UPDATE
 */
$stmt = $conn->prepare(
    'SELECT username, display_name, email
     FROM user_profiles
     WHERE username = ?'
);
$stmt->bind_param('s', $currentUser);
$stmt->execute();
$profile = $stmt->get_result()->fetch_assoc();
if (!$profile) {
    http_response_code(404);
    exit('Profile not found.');
}
$message = $_GET['message'] ?? '';
?>
```

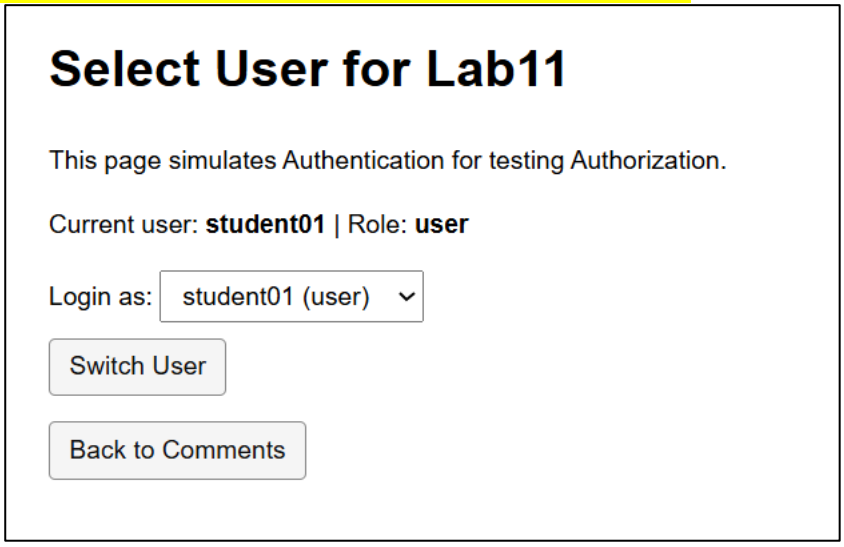
```html
<!doctype html>
<html lang="en">
<head>
    <meta charset="utf-8">
    <title>My Profile</title>
    <style>
        body {
            font-family: Arial, sans-serif;
            max-width: 900px;
            margin: 32px auto;
            padding: 0 16px;
            line-height: 1.5
        }
        .actions {
            display: flex;
            gap: 8px;
            margin-top: 10px;
            align-items: center
        }
        .actions form {
            margin: 0
        }
```

```
        button,
        .button-link {
            display: inline-flex;
            align-items: center;
            justify-content: center;
            min-width: 80px;
            height: 36px;
            padding: 0 12px;
            border: 1px solid #888;
            border-radius: 4px;
            background: #f5f5f5;
            color: #111;
            text-decoration: none;
            cursor: pointer;
            box-sizing: border-box;
            font: inherit
        }
        .nav-actions {
            display: flex;
            gap: 8px;
            flex-wrap: wrap;
            margin: 12px 0 20px
        }
    </style>
</head>

<body>
    <h1>My Profile</h1>
    <p>User: <strong><?= h($profile['username']) ?></strong></p>
    <?php if ($message !== ''): ?>
        <p><?= h($message) ?></p>
    <?php endif; ?>
    <form method="post" action="Lab11_update_profile.php">
        <label for="display_name">Display Name:</label>
        <input type="text" name="display_name" id="display_name"
            maxlength="100" value="<?= h($profile['display_name']) ?>" required>
        <br><br>
        <label for="email">Email:</label>
        <input type="email" name="email" id="email"
            maxlength="150" value="<?= h($profile['email']) ?>" required>
        <input type="hidden" name="csrf_token"
            value="<?= h($_SESSION['csrf_token']) ?>">
        <div class="actions">
            <button type="submit">Update Profile</button>
        </div>
    </form>
    <p><a class="button-link" href="Lab11_comments_secure.php">Back to Comments</a></p>
</body>
</html>
```

งานที่ 1.1: ทดสอบการสลับผู้ใช้และ Role

1) เปิด http://localhost:8080/Lab11/Lab11_select_user.php




2) เลือก student01 (user) แล้วตรวจหน้า Lab11_comments_secure.php จากนั้น Capture ผลลัพธ์
3) เลือก student02 (user) แล้วตรวจว่าข้อมูล Comment เปลี่ยนเป็นของผู้ใช้นั้น จากนั้น Capture ผลลัพธ์
4) เลือก admin01 (admin) แล้วตรวจว่ามีปุ่ม/ลิงก์ View All Comments สำหรับหน้า Admin จากนั้น Capture ผลลัพธ์

งานที่ 1.2: ทดสอบ Authorization ของหน้า Admin

1) สลับเป็น student01 (user) แล้วเปิด Lab11_admin_comments.php โดยตรง(URL: http://localhost:8080/Lab11/Lab11_admin_comments.php) จากนั้น Capture ผลลัพธ์

สลับเป็น admin01 (admin) แล้วเปิด URL เดิมอีกครั้ง จากนั้น Capture ผลลัพธ์

งานที่ 2.1: ทดสอบ Edit และการเข้าถึงข้อมูลของผู้อื่น

1) สลับเป็น student01 (user) แล้ว Edit Comment ของ student01 ตามปกติ จากนั้น Capture ผลลัพธ์
ผลที่คาดหวัง: user แก้ของตนเองได้ แต่ของผู้อื่นต้องได้ Access denied.

2) เปลี่ยน id ใน URL ของ Lab11_edit_form.php ให้เป็น Comment ของ student02
URLก่อน: http://localhost:8080/Lab11/Lab11_edit_form.php?id=6
URLหลัง: http://localhost:8080/Lab11/Lab11_edit_form.php?id=2

3) สลับเป็น admin01 (admin) แล้วเปิด id ของ student02 อีกครั้ง

URLก่อน: http://localhost:8080/Lab11/Lab11_edit_form.php?id=13
URLหลัง: http://localhost:8080/Lab11/Lab11_edit_form.php?id=2

งานที่ 2.2: ทดสอบ CSRF Token กับ Add/Edit/Delete

1) Add Comment ผ่าน Form ปกติและตรวจว่าบันทึกได้ จากนั้น Capture ผลลัพธ์หน้าจอและฐานข้อมูล

2) ทดลอง Edit โดยกดปุ่ม Edit จะแสดงหน้าจอแก้ไข จากนั้นโดยเปิด Developer Tools ⟶ Elements แล้วแก้ค่า csrf_token ใน Edit Form เป็น test123 แล้วกดปุ่ม Save Changes จากนั้น Capture ผลลัพธ์หน้าจอ

3) ทดลอง Delete โดยเปิด Developer Tools ⟶ Elements แล้วแก้ค่า csrf_token ภายใน Delete Form เป็น test123 ก่อนกดปุ่ม Delete

3.10Lab11_update_profile_before_csrf.php Endpoint สำหรับทดสอบกรณีที่ยังไม่ตรวจ CSRF Token

```php
<?php
require_once 'Lab11_config.php';
/* ใช้สาธิต "ก่อนป้องกัน CSRF"
 * ใช้เฉพาะในสภาพแวดล้อม Lab เท่านั้น
 */
if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    http_response_code(405);
    exit('Method not allowed.');
}
$displayName = trim($_POST['display_name'] ?? '');
$email = trim($_POST['email'] ?? '');
if (
    $displayName === '' ||
    mb_strlen($displayName, 'UTF-8') > 100 ||
    !filter_var($email, FILTER_VALIDATE_EMAIL) ||
    strlen($email) > 150
) {
    http_response_code(400);
    exit('Invalid request.');
}

$stmt = $conn->prepare(
    'UPDATE user_profiles
     SET display_name = ?, email = ?
     WHERE username = ?'
);
$stmt->bind_param('sss', $displayName, $email, $currentUser);
$stmt->execute();
header(
    'Location: Lab11_profile.php?message=' .
        urlencode('Profile updated WITHOUT CSRF protection.')
);
exit;
```

3.11 Lab11_update_profile.php Secure Endpoint ที่ตรวจ CSRF Token ก่อน UPDATE Profile (นักศึกษาสร้างเอง)

งานที่ 3.1: ทดสอบ Fake Profile Update ก่อนมี CSRF Protection

1) สลับเป็น student01 (user) และเปิด Lab11_profile.php เพื่อแสดงค่า Profile เดิม
2) เปิด http://localhost:8080/Lab11/Lab11_fake_profile_update.html
3) กด Send Fake Update (Before CSRF)
4) กลับไปจากนั้น Capture ผลลัพธ์หน้าจอ Lab11_profile.php หรือตาราง user_profiles

งานที่ 3.2: ทดสอบ Fake Profile Update หลังมี CSRF Protection

1) สลับเป็น student02 (user) และเปิด Lab11_profile.php เพื่อแสดงค่า Profile เดิม
2) เปิด http://localhost:8080/Lab11/Lab11_fake_profile_update.html
3) กด Send Fake Update (After CSRF)
4) ตรวจ Profile หลังทดสอบและจากนั้น Capture ผลลัพธ์หน้าจอหรือตาราง user_profiles
5) จากนั้นแก้ Profile ผ่าน Lab11_profile.php ตามปกติ และจากนั้น Capture ผลลัพธ์หน้าจอหรือตาราง user_profiles

